Interview guide

Privacy and confidentiality risks in AI and ML

This guide gives an overview of the topics we would like to discuss.

The interview is semi-structured, so we may ask questions in a different order or explore a topic in more depth depending on how the conversation develops. There are **no right or wrong answers**. We are interested in your experience and perspective as a practitioner in your field.

We will first discuss your use of AI and the sensitivity of your data, then consider three types of confidentiality attack. We will explore the attack or attacks most relevant to your domain in more detail.

1 AI use and information sensitivity

Q1. What do you or your team use AI/ML systems for, and where do you get the models from?

Q2. What kinds of data are typically used in your organisation or project for training or fine-tuning AI models?

Q3. Overall, how sensitive would you consider the data used for training ML/AI models, on a scale from 1 to 5?

Why?

Scale: 1 = not sensitive at all; 2 = slightly sensitive; 3 = moderately sensitive; 4 = sensitive; 5 = very sensitive.

Q4. Which kinds of information or data would you consider especially sensitive, private, or confidential in your domain?

Why?

Q5. Does your organisation currently monitor, assess, or mitigate privacy and confidentiality risks related to AI systems?

What processes or tools do you use?

Who is responsible for these activities?

Q6. Have you heard of or come across privacy or confidentiality incidents involving AI in practice?

2 Privacy and confidentiality attacks

Model access

White-box access means that an attacker can inspect the model's architecture and parameters and examine how it processes inputs.

Black-box access means that an attacker can provide inputs and observe outputs without access to the model's architecture or parameters.

Q7. Could an attacker realistically have black-box or white-box access to the model?

Could you give an example of how they might obtain such access?

Property inference attacks

Property inference attacks (PIAs) try to infer statistical information about the data used to train a model from access to that model. For example, an attacker might infer whether the training data contain many records from a particular demographic group, customer segment, or region.

Consider an attacker with white-box access to the target model and its internal parameters, and auxiliary data similar to the target training data.

Q8. Would you consider property inference attacks a confidentiality risk in your organisation?

Why or why not?

Can you think of a potential threat scenario?

Q9. How realistic do you consider it that an attacker would have access to auxiliary data?

Why?

Membership inference attacks

Membership inference attacks (MIAs) try to infer whether a particular data sample was included in the training set of a model, using black-box or white-box model access.

The attacker needs a candidate record to test against the model. They can check whether a specific, known person was included in training, but cannot discover unknown members from scratch.

Q10. Would you consider membership inference a confidentiality risk in your organisation?

Why or why not?

Can you think of a potential threat scenario?

Q11. How realistic is it that an attacker could obtain a specific record to test for membership in the training data?

Reconstruction and attribute inference attacks

Reconstruction attacks (RAs) aim to recreate original training samples or infer an unknown label or attribute of a known data sample from model access.

Q12. Would you consider reconstruction attacks a confidentiality risk in your organisation?

Why or why not?

Can you think of a potential threat scenario?

Q13. How realistic is it that an attacker could obtain partial information about a record and use it to infer sensitive attributes?

Selecting an attack for further discussion

Q14. Which of these attacks concerns you the most in practice, and why?

How would you rank them in terms of likelihood and impact?

We will now focus on the attack or attacks most relevant to your domain. Please use the corresponding section below.

3 Detailed discussion of the selected attack

Membership inference attacks

MIA1. Who might be interested in obtaining membership information, and what would they use it for?

MIA2. What kind of harm could result from this?

Who would be affected?

Why?

MIA3. How likely do you think your organisation is to be affected by a membership inference attack?

Why?

Scale: 1 = very unlikely (almost never); 2 = unlikely (rare); 3 = possible under some conditions; 4 = likely (realistic); 5 = very likely (expected or already happening).

MIA4. Overall, how severe do you consider the potential negative impact of membership inference attacks?

Why?

Scale: 1 = not severe (negligible impact); 2 = slightly severe (minor impact); 3 = moderately severe (noticeable impact); 4 = severe (significant impact); 5 = very severe (critical impact).

MIA5. Would membership leakage concerning a single individual already be a significant privacy concern, or does the scale of the leakage matter?

MIA6. Which characteristics or circumstances of the affected individuals influence how you would assess the severity of a membership inference attack?

If so, how?

MIA7. How confident would an attacker need to be before you would consider MIA a privacy violation?

Would even a low-confidence guess (for example, 60%) already concern you, or would it need to be much closer to certain (100%)?

Why?

Example: "I am 60% sure this person's data was used to train the model", versus "I am 95% sure."

Property inference attacks

PIA1. What kinds of properties or characteristics of the training data would you be most concerned about an attacker learning?

PIA2. Who might be interested in obtaining dataset-level information, and what would they use it for?

PIA3. What kind of harm could result from this?

Who would be affected?

Why?

PIA4. How likely do you think your organisation is to be affected by a property inference attack?

Why?

Scale: 1 = very unlikely (almost never); 2 = unlikely (rare); 3 = possible under some conditions; 4 = likely (realistic); 5 = very likely (expected or already happening).

PIA5. Overall, how severe do you consider the potential negative impact of property inference attacks?

Why?

Scale: 1 = not severe (negligible impact); 2 = slightly severe (minor impact); 3 = moderately severe (noticeable impact); 4 = severe (significant impact); 5 = very severe (critical impact).

PIA6. Are there any people or groups that would be particularly affected if property information were leaked?

PIA7. Before any attack, how well could a competitor in your sector already estimate [PROPERTY], just from knowing the industry?

Now suppose someone with access to your model could do better than that. How much better would it have to be before you would call it a leak rather than a good guess?

PIA8. How confident would an attacker need to be about a dataset-level estimate before you would consider it a confidentiality violation?

Would even a low-confidence estimate, just above a guess, already concern you, or would it need to be much closer to certain?

Property inference results also come with a confidence level rather than a certain fact. For example, an attacker might say, "I am 60% confident that the majority of your training data comes from customers in offshore territories", versus "I am 95% confident."

PIA9. Would you accept the risk of a property inference attack if the AI model provides significant value to your product or service?

Reconstruction attacks

RA1. What kinds of data records or attributes would be the most dangerous to have reconstructed?

RA2. Who might be interested in obtaining reconstructed data records or attributes, and what would they use them for?

RA3. What kind of harm could result from this?

Who would be affected?

Why?

RA4. How likely do you think your organisation is to be affected by a reconstruction attack?

Why?

Scale: 1 = very unlikely (almost never); 2 = unlikely (rare); 3 = possible under some conditions; 4 = likely (realistic); 5 = very likely (expected or already happening).

RA5. Overall, how severe do you consider the potential negative impact of reconstruction attacks?

Why?

Scale: 1 = not severe (negligible impact); 2 = slightly severe (minor impact); 3 = moderately severe (noticeable impact); 4 = severe (significant impact); 5 = very severe (critical impact).

RA6. Are there certain individuals, groups, or types of data for which attribute inference could be particularly harmful?

Why?

RA7. How close would reconstructed information need to be to the original data to constitute a confidentiality violation?

If only a range can be inferred, how narrow would it need to be to become concerning?

RA8. Suppose an attacker uses a model to infer a sensitive attribute about a person. Would it matter if the attacker were 60% confident in the inference versus 90%?

At what level of certainty would you consider such an inference a confidentiality violation?

4 Closing questions

C1. Do you have any final thoughts you would like to share?

C2. Do you have any colleagues you could recommend for an interview?

Thank you for your time and for sharing your perspective!